

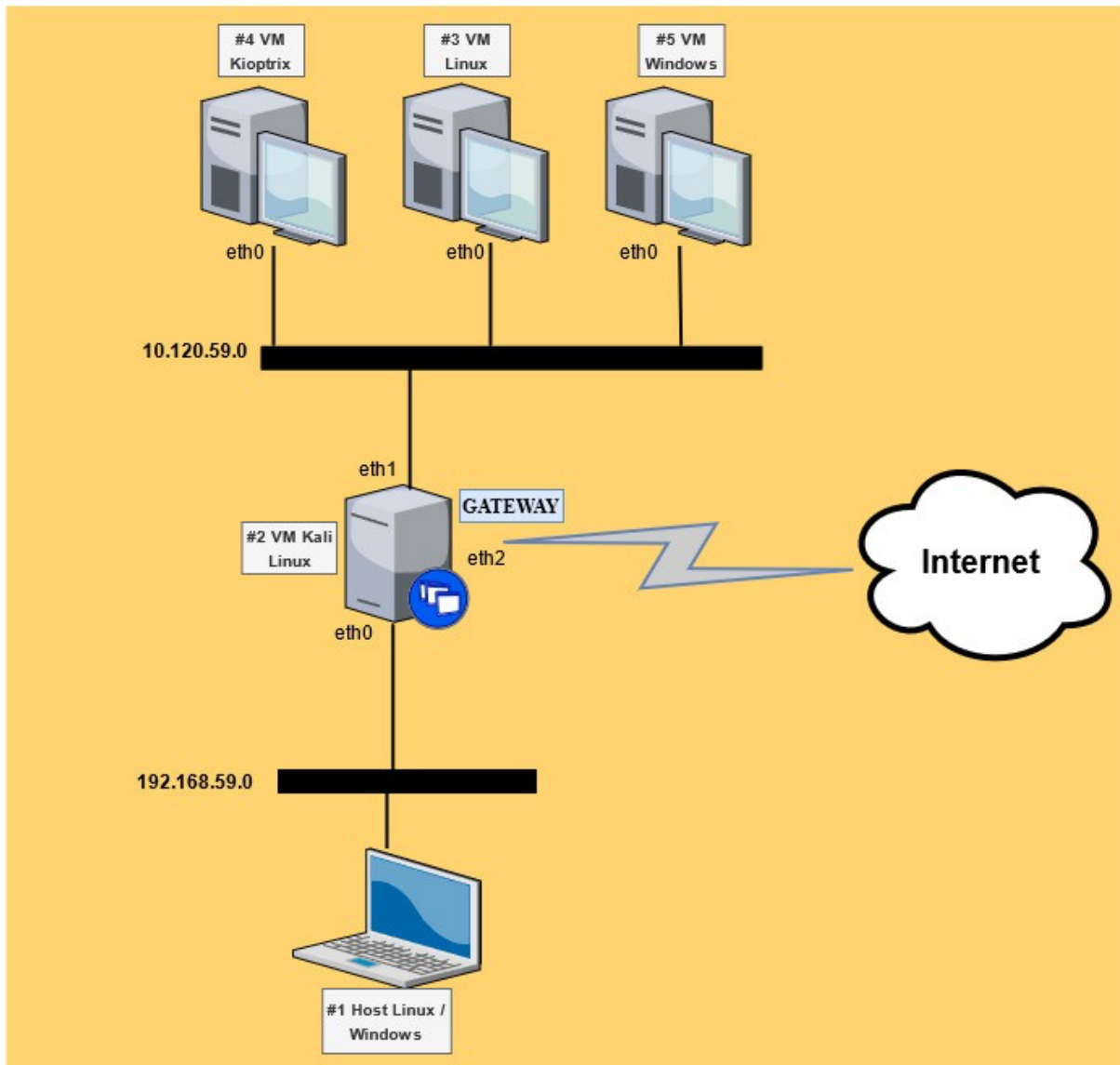
LICENCIATURA EM SEGURANÇA INFORMÁTICA EM REDES DE COMPUTADORES

SEGURANÇA DE REDES

Trabalho Prático 1

Análise de Vulnerabilidades

Parte I — Construção do Laboratório de Testes



- 1) Montar o cenário indicado.
- 2) Validar e documentar as conectividades entre todas as máquinas.
- 3) Comandos úteis (preferir a família ip(8); ifconfig/route estão deprecated em Debian/Kali modernos):
 - a) `ip addr add <ip>/<prefixo> dev eth0`
 - b) `ip link set eth0 up`
 - c) `ip route add <rede>/<prefixo> via <gateway>`
 - d) `sysctl -w net.ipv4.ip_forward=1` (aplica em tempo de execução)
 - e) `echo 'net.ipv4.ip_forward=1' >> /etc/sysctl.conf` (persistente após reboot)
 - f) `apt install <pacote>`
 - g) `cat /proc/sys/net/ipv4/ip_forward` (verificação)
- 4) Validar e garantir o funcionamento do gateway, incluindo o acesso à internet das máquinas #3 e #4.

Parte II — Análise de Tráfego

Usando a máquina #2, analise o tráfego que atravessa a gateway.

- a) Utilize tcpdump ou Wireshark.
- b) Comprove a conectividade entre as várias máquinas usando um dos sniffers. Documente.
- c) Instale o serviço FTP na máquina #3 e use-o a partir da máquina #1. Detete o user e a password a partir da máquina #2.
- d) Valide a existência dos serviços SSH e Telnet na máquina #3.
- e) Verifique e documente o fluxo de dados de uma ligação Telnet e de uma ligação SSH.
- f) Determine as diferenças entre esses dois serviços do ponto de vista da confidencialidade e integridade em trânsito.
- g) A partir de uma máquina com acesso à internet, valide e documente a diferença entre um acesso HTTP e um acesso HTTPS, incluindo a inspeção do handshake TLS.
- h) Sempre que recupere credenciais (FTP, hashes, etc.), tente o cracking com Hydra, John ou Hashcat e documente o processo, as wordlists utilizadas e o tempo de execução.

Parte III — Fases de Ataque

Executar o ciclo clássico de pentesting:

Reconnaissance → Scanning → Gaining Access → Post-Exploitation.

Documentar cada fase com evidências (screenshots e/ou pcaps) e discussão crítica dos resultados.

Reconnaissance e Scanning — nmap

- a) Procure as portas abertas em todas as máquinas.
- b) Use o nmap para tentar detetar os sistemas operativos das máquinas.
- c) Utilize scripts NSE (--script=default,vuln) para enriquecer o reconhecimento e discuta os resultados.

Scanning de Vulnerabilidades — Greenbone / OpenVAS

Nota: o projeto historicamente conhecido como OpenVAS foi renomeado para **Greenbone Community Edition** e integra-se no conjunto de ferramentas GVM (Greenbone Vulnerability Management). A documentação atualizada encontra-se em <https://www.greenbone.net/>.

- a) Ler a documentação da ferramenta de scanning de vulnerabilidades e documentar a instalação no ambiente de laboratório.
- b) Correr a ferramenta sobre as 3 máquinas-alvo (#3, #4 e #5).
- c) Elaborar relatório de vulnerabilidades encontradas, classificadas segundo o **CVSS v3.1** e, sempre que aplicável, mapeadas às técnicas do **MITRE ATT&CK**.

Gaining Access — Metasploit

O Metasploit é um framework de testes de penetração, com uma variante gratuita, referência na análise e exploração de vulnerabilidades. Instale a versão comunitária disponível em <https://www.metasploit.com/>.

- Aceda à base de dados da Rapid7 (<https://www.rapid7.com/db/>) e/ou à NVD (<https://nvd.nist.gov/>) e procure pelas falhas identificadas no exercício anterior.
- Caso não existam, procure por outras falhas conhecidas para as máquinas #4 (Kioptrix) e #5 (Windows).
- Para cada falha, identifique se há algum exploit ou módulo disponível.
- Liste, caso existam, os comandos do Metasploit necessários à sua exploração e execute-os com sucesso.

Post-Exploitation

- Após obter shell num alvo, recolha informação relevante do sistema comprometido: utilizadores, grupos, privilégios, binários SUID, serviços em execução, regras sudo.
- Identifique pelo menos um vetor de escalada de privilégios (análise manual ou com recurso a LinPEAS/WinPEAS) e documente a respetiva exploração.

Mitigação e Hardening

Para cada vulnerabilidade efetivamente explorada, proponha e implemente pelo menos duas medidas de mitigação. Exemplos ilustrativos, não exaustivos: substituir Telnet por SSH com autenticação por chave; fechar portas não essenciais com iptables/nftables; atualizar o serviço vulnerável; endurecer a configuração (desativar serviços, aplicar least privilege); aplicar segmentação de rede adicional no gateway.

Após aplicação das mitigações, reexecutar o teste correspondente e demonstrar, com evidências, que o vetor de ataque deixou de ser explorável.

Nota: Consulte <https://nmap.org/>, onde há uma lista exaustiva de ferramentas de segurança para todas as fases mencionadas, além de links úteis para download.

Datas importantes

Evento	Data
Disponibilização do Trabalho Prático 1	15/04/2026
Entrega do Trabalho Prático 1	19/05/2026

Composição dos grupos

Aceitam-se trabalhos feitos por grupos **até 2 elementos**

Avaliação

A avaliação do trabalho é feita de acordo com a rubrica seguinte. A cotação de cada tópico é modulada pelos descritores de desempenho apresentados abaixo.

Tópico	Cotação
Montagem do cenário	1
Validação de conectividade	1
Funcionamento da gateway (incluindo acesso à internet)	2
Análise de tráfego e criptografia em trânsito (Telnet/SSH, HTTP/HTTPS, deteção de credenciais FTP)	2
Instalação e utilização do nmap (incluindo NSE)	1
Instalação e utilização do Greenbone/OpenVAS + relatório CVSS v3.1	2
Instalação e utilização do Metasploit	2
Hacking Kioptrix (exploração + pós-exploração)	2
Hacking Windows (exploração + pós-exploração)	2
Mitigação e hardening (pelo menos 2 medidas por alvo + validação)	1
Relatório escrito	2
Defesa e apresentação	2
TOTAL	20